

COMP232 Lab 1

Lab 1: Practical Attacks on Passwords

In this lab session, you will learn about basic attacks on passwords, and password strength. Passwords are stored in an *encrypted* form. This involves running an encryption algorithm on the plain text password, and storing the output of the algorithm. A very popular algorithm for encryption was the [Secure Hash Algorithm 1 \(SHA1\)](#), which computes a [hash function](#). The output of hash functions are typically called *hash strings*, or simply *hash*. The SHA1 algorithm has now been discontinued and more sophisticated ones have taken its place. However, it is still a nice example to study.

1. SHA1 Hash table attack

Can you recover a password from its *hash*?

1. Create a *hash* of any password that you want to attack using an online sha1 hash generator (Eg: www.sha1-online.com). For example, the SHA1 hash for the string "MyPassword)" is ee484a6183ce6c6ccb171933aa9b4698f777de35
2. Copy the hash and go to any public SHA1 hash decrypter website and try to get equivalent text to it. (Eg: <https://www.dcode.fr/sha1-hash>, or <https://sha1.web-max.ca/>)
3. Try a hash table attack for the following passwords (sha1 hash) by using the same website. (i.e., compute the hash for the password string as in part 1, and then try to decrypt the hash as done in part 2).

SI No.	Password	Worked? (Yes/No)
1	P@\$\$W0rD	
2	Thisismypassword	
3	VeryLongP@\$\$W0rD	

2. Has my account password been leaked?

1. Open <https://haveibeenpwned.com/>
2. Provide your email and check if your account password has been leaked previously. If yes, you have to change your password!

Who's Been PwnedPasswordsNotify MeAPIDemosPricingAbout Dashboard

Have I Been Pwned

Check if your email address is in a data breach

Using Have I Been Pwned is subject to the [terms of use](#)

943
pwned websites

17,436,395,514
pwned accounts

3. Password strength against *brute-force* attacks

Note:

1. Don't Enter your real password!
2. The time it will take depends on processing speed.

1. Open the following password strength evaluators:
 1. Security.org: <https://www.security.org/how-secure-is-my-password/>
 2. Kaspersky <https://password.kaspersky.com/>.
2. Try the passwords in the table and check the time needed to brute-force them.
3. Can you propose a password which you would easily remember, and which has an estimated 1 Day to crack (by either services)?

Password	Time on security.org	Time on Kaspersky
P@S\$W0rD		
thisismypassword		
VeryLongP@\$W0rD		
%O^t#2Fv0JUjVdRV2RW%		